

Shodan · Censys · FOFA

These three are **internet-wide scanning search engines** — they continuously scan the entire IPv4 (and increasingly IPv6) address space and index what they find (banners, headers, certificates, ports, services), letting you *search* that pre-scanned data instead of scanning targets yourself. This is a fundamentally different OSINT category from theHarvester/Amass (which pull from search engines, DNS, and public records) — these three are pulling from **their own active internet-wide scans**, which happened before you ever typed a query.

1. The Core Concept — Why These Tools Exist

Normally, to find out "what's running on port 27017 (MongoDB) at this IP," you'd need to scan it yourself with Nmap — an *active* technique that touches the target and can be logged/detected.

Shodan, Censys, and FOFA have already done that scanning globally, continuously, across the entire internet. So querying them is **passive** from your side — you're searching a third-party's pre-existing index, never touching the target directly. This is exactly why they're OSINT tools, not scanning tools, even though the underlying data came from scanning.

```
Traditional approach:  You → Nmap → Target (active, detectable)
Shodan/Censys/FOFA:   You → Their Index → (Target already scanned by them, days/weeks ago)
```

2. PART 1: Shodan — "The Search Engine for the Internet of Things"

a) What It Indexes

Shodan connects to devices/services and stores the raw **banner** — literally the text a service returns on connection (SSH version strings, HTTP headers, FTP welcome messages, industrial control system responses, webcam interfaces, database error messages, etc.).

b) Basic Web Search

<https://www.shodan.io/search?query=apache>

c) Search Filters (the real power of Shodan)

Filter	Function	Example
<code>country:</code>	Restrict to a country	<code>country:IN</code>
<code>city:</code>	Restrict to a city	<code>city:Mumbai</code>
<code>org:</code>	Organization/ISP name	<code>org:"Reliance Jio"</code>
<code>hostname:</code>	Domain/hostname	<code>hostname:example.com</code>
<code>port:</code>	Specific port	<code>port:3389</code>
<code>product:</code>	Software/service name	<code>product:MongoDB</code>
<code>os:</code>	Operating system	<code>os:"Windows Server 2012"</code>
<code>net:</code>	CIDR range	<code>net:192.168.1.0/24</code>
<code>before:</code> / <code>after:</code>	Date range	<code>after:2025-01-01</code>
<code>has_screenshot:true</code>	Only results with a captured screenshot	(for webcams/RDP/VNC)

d) Practical Queries

```
# Exposed RDP in India
port:3389 country:IN

# MongoDB with no authentication (classic misconfiguration finding)
product:"MongoDB" -authentication country:IN

# Elasticsearch instances leaking data
product:"Elasticsearch" port:9200

# A specific organization's exposed infrastructure
org:"Company Name"

# Default-configuration webcams
"Server: SQ-WEBCAM"

# Exposed industrial control systems (ICS/SCADA - high sensitivity, authorized research only)
tag:ics country:IN
```

e) CLI Usage

```

pip install shodan
shodan init YOUR_API_KEY

shodan search "org:'Company Name'"
shodan host 8.8.8.8 # detailed info on a
specific IP
shodan count "product:MongoDB" # just a count, doe
sn't use query credits
shodan download results apache # save raw results
for offline processing
shodan parse results.json.gz --fields ip_str,port,org

```

f) Shodan Monitor / Alerts

Shodan can track a defined set of your own IPs and alert you when something new appears — legitimate defensive use case (continuous external attack surface monitoring), separate from its offensive recon use.

g) Free vs. Paid Tier Limitations

The free tier severely limits query credits and results-per-search — enough to learn the tool and do small targeted lookups, but a full org-wide sweep typically needs a paid membership (relatively affordable, and academic discounts exist).

3. PART 2: Censys — Certificate-Centric Internet Scanning

a) What Makes It Different From Shodan

Censys scans similarly but is generally considered **stronger for TLS/certificate-based pivoting** — finding every host that shares a specific certificate, certificate issuer, or certificate fingerprint is a core Censys strength, useful for mapping infrastructure that shares config even across different IPs/domains.

b) Basic Web Search

```
https://search.censys.io/search?resource=hosts&q=services.service_name:MONGODB
```

c) Search Syntax (structured field-based queries)

```
services.service_name: HTTP
services.port: 443
location.country: India
autonomous_system.name: "Company Name"
services.tls.certificates.leaf_data.subject.organization: "Company Name"
```

d) Practical Queries

```
# All hosts in India running exposed MongoDB
services.service_name: MONGODB and location.country: India

# Hosts presenting a certificate for a specific organization (infra mapping)
services.tls.certificates.leaf_data.subject.organization: "Company Name"

# Exposed Elasticsearch instances
services.service_name: ELASTICSEARCH

# Hosts on a specific ASN (autonomous system)
autonomous_system.asn: 15169
```

e) Certificate Pivoting (Censys's Signature Technique)

If you find one server's TLS certificate, you can search for **every other host presenting the same certificate** — extremely useful for mapping load-balanced infrastructure, shared hosting, or infrastructure an org forgot was still tied to an old cert:

```
services.tls.certificates.leaf_data.fingerprint_sha256: "<cert_hash>"
```

f) CLI Usage

```
pip install censys
censys config # set API ID/sec
ret

censys search "services.service_name: HTTP and location.country: India"
censys hosts view 8.8.8.8
```

g) Censys vs. Shodan — Direct Comparison

	Shodan	Censys
Query syntax	Simpler, filter-based	More structured/verbose field syntax
Certificate pivoting	Basic	Strong — a core differentiator
Screenshots	Yes (webcams, RDP, VNC)	Limited
ICS/SCADA focus	Strong, well-known for this	Less emphasized
Free tier	Limited credits	Limited queries, similar constraints

Practical takeaway: many practitioners use both — Shodan for broad device/service discovery (especially anything with a visual/screenshot component like webcams or RDP), Censys when the investigation is anchored around certificates or precise structured filtering.

4. PART 3: FOFA — The China-Centric Equivalent

a) What It Is

FOFA (fofa.info) is a Chinese internet-scanning search engine, functionally similar to Shodan/Censys, but with notably **stronger coverage of Chinese and broader Asia-Pacific infrastructure** — a region where Shodan/Censys sometimes have gaps. It's widely used by security researchers who need APAC-region visibility.

b) Basic Query Syntax

```
title="admin login"
app="MongoDB"
country="CN"
port="3389"
header="Server: nginx"
```

c) Practical Queries

```
# Find a specific web application/product
app="ThinkPHP"

# Exposed login panels
title="后台管理" || title="admin login"

# Specific port + country combo
```

```
port="6379" && country="CN"          # exposed Redis in China

# Organization-scoped search
org="Company Name"
```

d) Why It's Worth Knowing (Even If You Won't Use It Daily)

- If a target organization has infrastructure or subsidiaries in China/APAC, FOFA sometimes surfaces assets Shodan/Censys miss entirely, since crawler coverage isn't perfectly global/uniform across all three platforms
- Threat intelligence teams tracking APT infrastructure (many of which route through or originate from APAC-region hosting) commonly cross-reference FOFA alongside Shodan/Censys for more complete coverage
- It's a good example of *why* professional OSINT work often uses multiple scanning search engines rather than relying on just one — no single platform has perfect global coverage

e) Access Notes

FOFA's interface and documentation are primarily in Chinese (though partial English support exists), and its free tier is quite limited — most serious use requires a paid account. Worth knowing it exists and what it's for, even if Shodan/Censys remain your primary daily-driver tools.

5. Combining All Three — Practical Workflow

1. Shodan → broad device/service discovery, screenshots, ICS/webcam-specific searches
2. Censys → certificate pivoting, precise structured filtering, infra mapping
3. FOFA → fill coverage gaps, especially APAC-region infrastructure

Example combined recon on an org:

```
shodan search "org:'Company Name'"
```

```
censys search "services.tls.certificates.leaf_data.subject.organization: 'Company Name'"
```

```
fofa: org="Company Name"
```

→ Cross-reference results across all three

→ Deduplicate IPs/hosts found

→ Feed confirmed live hosts into deeper analysis (banner review, version identification)

→ Cross-check discovered software/versions against known CVEs (this is exactly

the workflow your SmartScan project's NVD lookup logic already mirrors, just starting from passive data instead of an active Nmap scan)

6. Real-World Significance — Why This Category Matters So Much

These tools are responsible for some of the most consequential security research findings of the last decade:

- Mass discovery of **exposed, unauthenticated MongoDB/Elasticsearch instances** leaking millions of records — a recurring headline story, almost always found via Shodan/Censys-style searches rather than targeted attacks
- Identification of **exposed ICS/SCADA systems** (water treatment plants, industrial controllers) — critical infrastructure researchers use Shodan specifically because manually scanning would be both impractical and legally risky, whereas querying an existing index isn't
- **Ransomware groups and threat actors also use these tools** for the exact same reason defenders do — finding exposed, vulnerable services at scale is valuable to both sides, which is precisely why organizations need to actively monitor their own exposure on these platforms (see Section 8)

7. Legal & Ethical Notes

- **Querying Shodan/Censys/FOFA is legal** — you're searching a third party's published index, not scanning anything yourself
- **What you do with the results is where authorization matters** — finding an exposed MongoDB instance via Shodan and then connecting to it and reading customer data is unauthorized access, even though the *discovery* step was passive and legal
- For professional engagements, using these tools to map a client's *known, in-scope* assets is standard practice; using them to explore unrelated organizations "just to see what's out there" crosses from research into something legally murkier depending on jurisdiction and intent
- Many security researchers responsibly disclose exposed databases/services they find via Shodan to the affected organization rather

than accessing the data — this is considered good practice in the security research community

8. Defensive Angle — Using These Tools on Yourself (High-Value, Directly Actionable)

This is genuinely one of the most practical applications for someone in your position:

```
# Check what Shodan already knows about your own public IP/
infrastructure
shodan host <your_public_ip>

# Search for your own organization/domain
shodan search "hostname:yourdomain.com"
```

Why this matters: if Shodan already indexed an exposed service on your infrastructure, an attacker doesn't even need to scan you — they just search for you. This is why **continuous external attack surface monitoring** using exactly these platforms is now a standard part of mature security programs, and Shodan explicitly sells "Shodan Monitor" for this defensive use case.

Worth doing this against your own home lab/router setup as a safe, legal way to practice — you'll likely be surprised what's already indexed about your own public-facing IP if you've ever exposed anything (even briefly) to the internet.

9. Kill Chain / ATT&CK Mapping

Tool	Framework Mapping
Shodan / Censys / FOFA	Reconnaissance — T1596.005 (Search Open Technical Databases: Scan Databases) — this is the specific ATT&CK sub-technique that exists <i>because</i> of tools exactly like these three

Worth noting T1596.005 explicitly calls out Shodan and Censys by name in MITRE's own documentation — a good sign of how central these tools are considered to modern adversary (and defender) tradecraft.

Quick Reference Cheat Sheet

Shodan

```
shodan search "org:'Company Name'"
```

```
shodan search "product:MongoDB -authentication country:IN"
```

```
shodan host 8.8.8.8
```

```
shodan count "port:3389 country:IN"
```

Censys

```
censys search "services.service_name: HTTP and location.country: India"
```

```
censys hosts view 8.8.8.8
```

FOFA (web query syntax)

```
app="ThinkPHP"
```

```
org="Company Name"
```

```
port="6379" && country="CN"
```

Web interfaces:

```
https://www.shodan.io  
https://search.censys.io  
https://fofa.info
```